

Documentations des attaques avec MITRE ATT&ck

Thursday, May 14, 2020 11:51 AM

Nom de l'attaque	Techniques Mitre	Description de l'attaque	Impact de l'attaque	Communucation affectee	Donnees modifier	Detection possible
Replay attack	T1212 – Exploitation for Credential Access	L'attaquant intercepte des paquets de données envoyés entre les capteurs et le système puis les rejoue plus tard afin de tromper le système avec d'anciennes données considérées comme légitimes.	Le système croit recevoir des données réelles alors que les informations sont anciennes. Cela peut provoquer de mauvaises décisions IA, masquer des anomalies et créer une fausse stabilité du système.	Communication entre les capteurs, les passerelles réseau et le cloud Azure.	Séries temporelles, valeurs de consommation, données capteurs, paquets réseau authentifiés.	Détection par horodatage, numéros de séquence, analyse temporelle, détection d'anomalies IA, authentification forte, signatures numériques.
Sensor Spoofing (Spoof Reporting Message)	Unauthorized Message: Reporting Message / anciennement Spoof Reporting Message	Un faux capteur envoie de fausses informations en imitant un capteur légitime afin de tromper le système industriel ou IoT.I	Mauvaises décisions automatiques, contamination du système, perte de confiance dans les mesures, possibilité de sabotage.	Communication entre le capteur et le contrôleur (PLC, SCADA, serveur IoT).	Valeurs des capteurs : température, pression, vitesse, niveau, état machine, etc.	Détection des valeurs incohérentes, comparaison avec d'autres capteurs, surveillance réseau, authentification des messages, anomalies dans les journaux système.
Adversary-in-the-Middle (AITM)	T0830 – Adversary-in-the-Middle	L'attaquant intercepte les communications réseau entre deux équipements industriels ou IoT afin de lire, bloquer, modifier ou injecter des messages en temps réel. Cette attaque peut utiliser l'ARP poisoning ou un proxy malveillant.	Vol d'informations, modification des commandes, interruption des processus industriels, usurpation d'identité, sabotage du système.	Communication entre PLC, SCADA, HMI, serveurs, routeurs, VPN et équipements réseau.	Messages réseau, commandes de contrôle, paramètres système, données de capteurs, identifiants d'authentification.	Surveillance des anomalies réseau, détection d'ARP spoofing, analyse des journaux réseau, détection d'hôtes inconnus, surveillance des processus suspects comme iptables, IDS/IPS réseau.
Denial of Service (DoS)	T0814 – Denial of Service	L'attaquant cherche à rendre un système ou un équipement indisponible en surchargeant le dispositif, en exploitant une vulnérabilité ou en envoyant des requêtes malformées. Cela peut empêcher les équipements ICS/SCADA de fonctionner normalement ou de répondre aux commandes.	Arrêt des opérations, perte d'accès aux équipements, interruption des services industriels et impossibilité de contrôler cert	Communications réseau ICS/SCADA, services SSH, HTTP, Telnet, SNMP et communications entre automates et serveurs..	Tables de routage, firmware des appareils, paquets réseau ou paramètres système pouvant provoquer le blocage des équipements.	Surveillance des anomalies réseau, détection de trafic inhabituel, analyse des logs système et détection des interruptions soudaines de communication ou de service.
Loss of Availability (Perte de disponibilité)	T0826 – Loss of Availability	L'attaquant perturbe ou rend indisponibles des systèmes industriels essentiels afin d'empêcher le fonctionnement normal des opérations. Cela peut inclure l'arrêt des automates industriels (PLC), des HMI, des serveurs ou le chiffrement/destruction de données critiques avec un malware ou un ransomware.	- Arrêt des opérations industrielles - Coupure de services essentiels - Perte de production et de revenus - Indisponibilité des équipements OT/ICS - Interruption temporaire ou prolongée des activités	- Communications entre PLC, HMI et serveurs de contrôle - Réseaux industriels OT/ICS - Communications de supervision et de contrôle - Accès réseau aux équipements industriels	- Suppression ou chiffrement des données critiques - Modification des paramètres des systèmes de contrôle - Altération des configurations industrielles - Blocage de l'accès aux bases de données et systèmes opératoires	- Surveillance des interruptions de service inhabituelles - Détection des arrêts soudains de PLC/HMI - Monitoring réseau pour identifier des pertes de communication - Analyse des journaux système et OT - Détection d'activités de ransomware ou malware - Surveillance des anomalies de disponibilité des équipements
Remote Services	T0886 – Remote Services	Les attaquants utilisent des services distants comme RDP, SSH, SMB, VNC ou Telnet pour accéder aux systèmes industriels, se déplacer latéralement entre les réseaux et contrôler des équipements à distance. Cette technique permet aussi d'exécuter des commandes, transférer des fichiers ou manipuler des systèmes ICS/OT.	Accès non autorisé aux systèmes industriels - Mouvement latéral dans le réseau OT/ICS - Exécution de commandes malveillantes - Prise de contrôle des équipements industriels - Risque d'arrêt des opérations ou sabotage	Communications RDP (Remote Desktop Protocol) - SMB / Windows Admin Shares - SSH et Telnet - VNC et protocoles d'accès distant - Communications entre réseau IT et OT	- Fichiers transférés ou chiffrés - Paramètres des systèmes industriels - Commandes exécutées à distance - Identifiants et comptes compromis - Configurations des équipements ICS	- Surveillance des connexions RDP, SSH, SMB et VNC inhabituelles - Détection d'accès à des systèmes non habituels - Analyse des journaux d'authentification et connexions distantes - Monitoring des mouvements latéraux dans le réseau - Détection des connexions à des heures anormales - Surveillance des transferts de fichiers via SMB ou accès administratifs distants
Masquerading (Masquage / Usurpation d'identité)	T0849 – Masquerading	L'attaquant déguise un fichier ou un programme malveillant en fichier légitime afin d'éviter la détection par les opérateurs ou les outils de sécurité. Cela peut inclure le renommage d'exécutables, l'utilisation de fausses extensions (.txt → .exe), ou le remplacement de DLL légitimes.	Exécution discrète de malware, compromission des systèmes ICS, persistance et contournement des défenses. Peut permettre sabotage, vol de données ou prise de contrôle.	Communications des postes HMI, serveurs d'applications, postes d'ingénierie et réseaux OT peuvent être interceptés ou manipulés par des programmes déguisés.	Fichiers système, DLL, exécutables, tâches planifiées, services Windows et configurations peuvent être remplacés ou renommés.	Surveillance des changements de noms de fichiers, comparaison hash/fichier attendu, détection des extensions suspectes, monitoring des services/tâches nouvellement créés, contrôle des signatures numériques, détection des fichiers dans des emplacements inhabituels.
Denial of Control	T0813 – Denial of Control (ICS)	L'attaquant empêche temporairement les opérateurs et ingénieurs d'interagir avec les systèmes de contrôle industriels. Les équipements industriels continuent parfois de fonctionner, mais les opérateurs perdent la capacité de surveiller ou modifier les processus.	- Perte de contrôle des équipements industriels - Interruption des opérations - Impossibilité pour les opérateurs d'envoyer des commandes - Risque de dysfonctionnement industriel - Perturbation des systèmes critiques	- Communications entre opérateurs et automates industriels (PLC/RTU) - Canaux série COM - Réseaux SCADA/HMI - Communications réseau industrielles	- Firmware des convertisseurs série-Ethernet - Paramètres des équipements industriels - États de contrôle des dispositifs - Configuration des systèmes de communication	MITRE indique qu'il n'existe pas encore de méthode standard de détection pour cette technique. Cependant, on peut surveiller : - pertes soudaines de communication avec les PLC/RTU - interruptions des canaux COM - impossibilité d'envoyer des commandes - anomalies dans les réseaux SCADA/HMI - comportements anormaux des équipements industriels - indisponibilité des interfaces opérateurs
Modify Parameter	T0836 – Modify Parameter (ICS)	L'attaquant modifie les paramètres utilisés par les systèmes de contrôle industriels (PLC, RTU, DCS, PAC, IED) afin de changer le comportement normal des processus industriels. Ces paramètres contrôlent par exemple la vitesse, la durée, la température, la fréquence ou l'état des équipements.	- Dysfonctionnement des équipements industriels - Processus industriels exécutés incorrectement - Dommages matériels potentiels - Risques de sécurité physique - Perturbation ou arrêt de production - Valeurs dangereuses ou hors limites normales	- Communications Modbus - Protocoles ICS/SCADA - Communications PLC ↔ HMI - Réseaux industriels - Profibus/EtherCAT - Échanges entre contrôleurs et dispositifs de terrain	- Registres industriels - Paramètres de configuration des PLC/RTU - Valeurs de fréquence, vitesse ou durée - États ON/OFF des équipements - Valeurs de contrôle des processus industriels	- Surveillance des changements de configuration des équipements - Analyse des journaux d'applications et logs industriels - Détection d'alarmes liées aux modifications de paramètres - Surveillance des protocoles ICS pour détecter des valeurs inhabituelles - Détection de changements effectués à des heures anormales - Contrôle des paramètres dépassant les valeurs normales de fonctionnement
Manipulate I/O Image	T0835 – Manipulate I/O Image (ICS)	L'attaquant manipule l'image d'entrée/sortie (I/O image) d'un PLC afin de modifier le comportement des équipements industriels. Cela peut être réalisé en modifiant directement la mémoire du PLC ou en utilisant les fonctions d'override destinées aux tests. L'objectif est de falsifier les entrées/sorties pour empêcher le système de fonctionner normalement ou masquer des actions malveillantes.	- Mauvais fonctionnement des équipements industriels - Commandes falsifiées envoyées aux dispositifs - Perte de fiabilité des processus industriels - Actions non autorisées sur les machines - Risque de dommages matériels ou interruption de production	- Communications PLC ↔ modules I/O - Échanges entre PLC et équipements de terrain - Réseaux de contrôle industriels - Communications internes des automates industriels	- Tables d'images d'entrées/sorties (I/O image tables) - Valeurs des entrées physiques - Valeurs des sorties physiques - Blocs mémoire du PLC - Données de contrôle des équipements	- Analyse des programmes exécutés sur les PLC - Surveillance des écritures anormales dans les blocs mémoire - Détection des modifications directes des tables I/O - Vérification des overrides inhabituels des entrées/sorties - Analyse des comportements incohérents entre commandes et états physiques des équipements
Manipulation of View	T0832 – Manipulation of View (ICS)	Technique où un attaquant modifie ou falsifie les informations affichées aux opérateurs afin de cacher l'état réel du système industriel. L'opérateur voit des données incorrectes pendant que le système fonctionne anormalement.	Mauvaises décisions des opérateurs, erreurs de contrôle industriel, risques de panne ou de dommages physiques, perte de confiance dans le système de supervision.	Communications entre PLC, HMI, SCADA, serveurs OPC et systèmes de supervision industriels.	Valeurs des capteurs, états des équipements, images I/O, données de supervision, informations affichées sur les interfaces opérateurs.	Vérification de l'authenticité des communications, comparaison des données via des canaux hors bande (Out-of-Band), surveillance des incohérences entre état réel et données affichées, analyse des flux ICS inhabituels, contrôle d'intégrité des données et journaux système.

Reconnaissance (Scan IP / Ports) : Utilisation d'Ettercap (requêtes ARP) et de NMap pour cartographier le réseau et identifier le port Modbus (TCP 502).

Marche à suivre :
Dataset → Prétraitement → Détection IA → Classification → Résultats
Deep Learning

Modèle	Utilité	
LSTM	Séries temporelle	s
CNN	Analyse de trafic	
Autoencoder	Detection anomalies	
GRU	Trafic industriel	

ICI je vais associer les attaques aux autres parametres pour faciliter le traitement des donnees

Attaque	Dataset	Modèle IA	Détection

Modele classique present dans IEEE

Modele	Utilite
Random Forest	cyber
XGBoost	Pour la precision
SVM	classification

Decision tree	
kNN	Pour la detection par similarite